

SOC/L1 14.4 - Boogeyman 3

Task 1 - Introduction

Due to the previous attacks of Boogeyman, Quick Logistics LLC hired a managed security service provider to handle its Security Operations Center. Little did they know, the Boogeyman was still lurking and waiting for the right moment to return.

In this room, you will be tasked to analyse the new tactics, techniques, and procedures (TTPs) of the threat group named Boogeyman. Lastly, it was presumed by the security team that the incident occurred between **August 29 and August 30, 2023**.

Task 2 - Scenario: The Chaos Inside

Lurking in the Dark: Without tripping any security defences of Quick Logistics LLC, the Boogeyman was able to compromise one of the employees and stayed in the dark, waiting for the right moment to continue the attack. Using this initial email access, the threat actors attempted to expand the impact by targeting the CEO, Evan Hutchinson. The email appeared questionable, but Evan still opened the attachment despite the scepticism. After opening the attached document and seeing that nothing happened, Evan reported the phishing email to the security team.

Initial Investigation: Upon receiving the phishing email report, the security team investigated the workstation of the CEO. During this activity, the team discovered the email attachment in the downloads folder of the victim.

1. What is the PID of the process that executed the initial stage 1 payload?

filter file name > projectfinancial*

Discover > Search > process.pid, process name, host.name, user.name, processcommandline, processparentcomandline,

initial payload is clicking link > check first alert > 6392 (1. hit run by mshta.exe file)

LotL technique abuses mshta.exe, a native Windows application designed to run Microsoft HTML Applications (.HTA files). Because mshta.exe is a signed, legitimate Microsoft program, it's often whitelisted by security software. Crucially, it can execute JavaScript and VBScript with the full permissions of the user, outside the confines of a browser's sandbox.

2. The stage 1 payload attempted to implant a file to another location. What is the full command line value of this execution?

Checked after executed process command line (2. hit copied)

"C:\Windows\System32\xcopy.exe" /s /i /e /h D:\review.dat

C:\Users\EVAN~1.HUT\AppData\Local\Temp\review.dat

3. The implanted file was eventually used and executed by the stage 1 payload. What is the full command-line value of this execution?

"C:\Windows\System32\rundll32.exe" D:\review.dat,DllRegisterServer (3. hit run rundll32.exe)

`rundll32.exe` utility to run the `DllRegisterServer` function from the file `review.dat` located on the `D:` drive. This is typically used to register a DLL file with the system

4. The stage 1 payload established a persistence mechanism. What is the name of the scheduled task created by the malicious script? (Review)

```
4.hit message - CommandLine: "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
$A = New-ScheduledTaskAction -Execute 'rundll32.exe' -Argument
'C:\Users\EVAN~1\HUT\AppData\Local\Temp\review.dat,DllRegisterServer'; $T = New-
ScheduledTaskTrigger -Daily -At 06:00; $S = New-ScheduledTaskSettingsSet; $P = New-
ScheduledTaskPrincipal $env:username; $D = New-ScheduledTask -Action $A -Trigger $T -
Principal $P -Settings $S; Register-ScheduledTask Review -InputObject
```

5. The execution of the implanted file inside the machine has initiated a potential C2 connection. What is the IP and port used by this connection?

Discover > Search > destinationIP and destinationport, check event id 3 or 11 for network connection, check > winlog.event_id: 3, 165.232.170.151:80

6. The attacker has discovered that the current access is a local administrator. What is the name of the process used by the attacker to execute a UAC bypass?

User Account Control (UAC) bypass is a technique used by attackers to gain elevated privileges on a Windows system without triggering a UAC prompt. UAC is a security feature in Windows designed to prevent unauthorized changes to the operating system by requiring administrator approval before executing actions that could affect the system's security or functionality.

According to hint > GitHub Gist > netbiosX | FodhelperUACBypass.pst

winlog.event_id: 3 , check > process creation > **fodhelper.exe**

Common UAC Bypass Techniques

Fileless Attacks: Attackers can leverage legitimate Windows utilities like **fodhelper.exe**, **eventvwr.exe**, or **sdclt.exe** to execute commands with elevated privileges without triggering a UAC prompt. These utilities have auto-elevate properties, meaning they do not require user interaction for elevation.

DLL Hijacking: Attackers can exploit vulnerable processes that load DLLs in an unsafe manner. By placing a malicious DLL in a location that the process checks first, the attacker can gain elevated privileges when the process loads the malicious DLL.

Windows Installer (msiexec.exe): The Windows Installer can be used to bypass UAC by launching an MSI package with elevated privileges. Attackers may use this to install malicious software without triggering a UAC prompt.

Scheduled Tasks: Attackers can create or modify scheduled tasks that run with elevated privileges. By doing so, they can execute their payloads with administrator rights without triggering UAC.

7. Having a high privilege machine access, the attacker attempted to dump the credentials inside the machine. What is the GitHub link used by the attacker to download a tool for credential

dumping?

search for github and also filter for the particular user, so the popular tool mimikatz is downloaded

https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip

8. After successfully dumping the credentials inside the machine, the attacker used the credentials to gain access to another machine. What is the username and hash of the new credential pair?

checked 1. mimikatz.exe after powershell execution >
itadmin:F84769D250EB95EB2D7D8B4A1C5613F2

9. Using the new credentials, the attacker attempted to enumerate accessible file shares. What is the name of the file accessed by the attacker from a remote share?

<https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/master/Recon/PowerView.ps1>:

This is the URL of the script being downloaded, which belongs to the PowerSploit framework. Specifically, this is a PowerShell script for PowerView, a tool used for network reconnaissance.

IT_Automation.ps1

10. After getting the contents of the remote file, the attacker used the new credentials to move laterally. What is the new set of credentials discovered by the attacker?

30 august > cmd usage > process.args > commands > UICKLOGISTICS\allan.smith

11. What is the hostname of the attacker's target machine for its lateral movement attempt?
you'll know this when checking the cmd used to access the file WKSTN-1327

12. Using the malicious command executed by the attacker from the first machine to move laterally, what is the parent process name of the malicious command executed on the second compromised machine?

Filter events with Event ID of 1 & WKSTN-1327" > **wsmprovhost.exe**

wsmprovhost.exe is a legitimate Windows process associated with Windows Remote Management (WinRM). It hosts Windows PowerShell remoting sessions and handles remote commands executed through WinRM

13. The attacker then dumped the hashes in this second machine. What is the username and hash of the newly dumped credentials? (format: username:hash)

administrator:00f80f2538dcb54e7adc715c0e7091ec

14. After gaining access to the domain controller, the attacker attempted to dump the hashes via a DCSync attack. Aside from the administrator account, what account did the attacker dump?

"C:\Users\Administrator\Documents\mimi\x64\mimikatz.exe" "Isadump::dcsync
/domain:quicklogistics.org /user:backupda" exit

15. After dumping the hashes, the attacker attempted to download another remote file to execute ransomware. What is the link used by the attacker to download the ransomware binary?

<http://ff.sillytechninja.io/ransomboogey.exe>

